Bloque 2: Ecosistema OWASP y Protección Proactiva

FADENA

OWASP y Protección Proactiva

Ing. Roxana Quiroga Sollinger

Protección Proactiva Parte1

Módulo 3: OWASP y Protección Proactiva

FADENA

3.1 OWASP

3.2 OWASP TOP 10

3.3 Protección Proactiva

3.4 Defensa en Profundidad



FADENA

3.3 Protección Proactiva

Alcances

Modelado de Amenazas

Threat Modelling es la identificación y evaluación de riesgos en la fase de diseño arquitectónico, antes de escribir una sola línea de código.

Codificación Segura

Adopción de estándares de programación que evitan por diseño fallos comunes (como inyecciones SQL, XSS o desbordamientos de memoria). (OWASP)



DevSecOps e Inspección Continua

Integración de pruebas automatizadas de análisis estático (SAST), dinámico (DAST) y de composición de software (SCA) en el pipeline de CI/CD.

Seguridad por Defecto

Security by Default es Configuración del sistema reduciendo al mínimo la superficie de ataque y aplicando el principio de mínimo privilegio de origen.

NIST SSDF

SSDF: Secure Software Development Framework

OWASP SAMM

SAMM: Software Assurance Maturity Model

FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

PERSONAL, PROCESOS Y TECNOLOGÍA

PROTEGER TODOS LOS COMPONENTES DEL SOFTWARE

PRODUCIR SOFTWARE ALTAMENTE SEGURO

IDENTIFICAR VULNERABILIDADES RESIDUALES



1. Preparar la Organización (PO)

Las organizaciones deben asegurarse de que su personal, sus procesos y su tecnología estén preparados para llevar a cabo el desarrollo de software seguro a nivel organizacional.

2. Proteger al Software (PS)

Las organizaciones deben proteger todos los componentes de su software contra la manipulación y el acceso no autorizado.

3. Producir Software Altamente Seguro (PW)

Las organizaciones deben producir software altamente seguro, minimizando las vulnerabilidades de seguridad en sus versiones publicadas.

4. Responder a las vulnerabilidades (RV)

Las organizaciones deben identificar las vulnerabilidades residuales en las versiones de su software y responder adecuadamente para abordarlas y evitar que surjan otras similares en el futuro.

FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

1. Preparar a la Organización (PO)

01

Definir los requisitos de seguridad para el desarrollo de software

Garantizar que los requisitos de seguridad para el desarrollo de software se conozcan en todo momento, y que se tengan en cuenta a lo largo del ciclo de vida de desarrollo de software (SDLC).

02

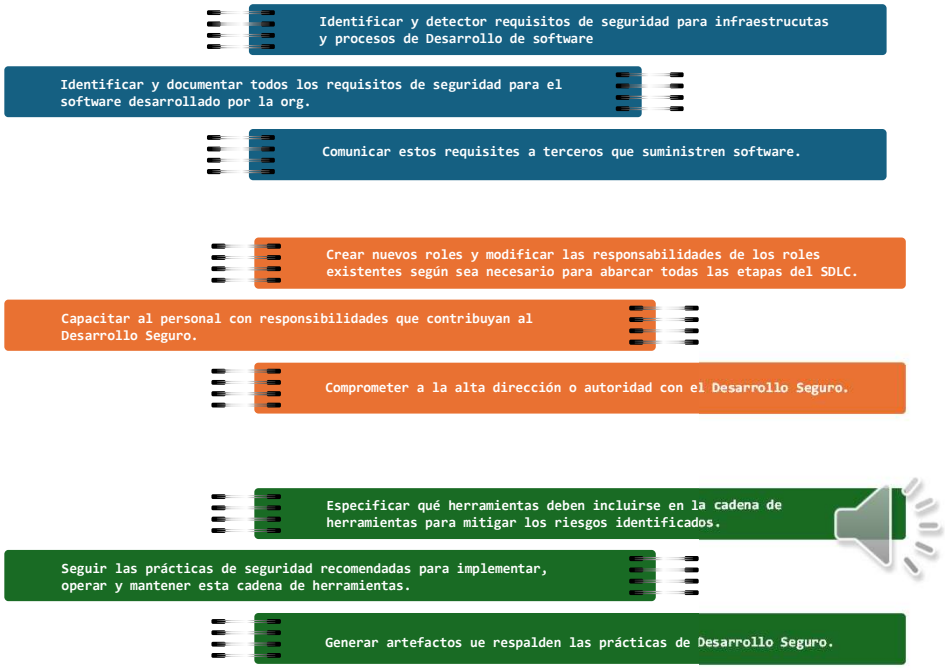
Implementar Roles y Responsabilidades

Asegurar que todas las personas, tanto dentro como fuera de la organización, que participan en el ciclo de vida de desarrollo de software (SDLC) estén preparadas para desempeñar sus roles y responsabilidades relacionados con el SDLC a lo largo de todo el proceso.

03

Automatizar

Utilice la automatización para reducir el esfuerzo humano y mejorar la precisión, reproducibilidad, usabilidad, y exhaustividad de las prácticas de seguridad en todo el SDLC.



FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

1. Preparar a la Organización (PO)

04

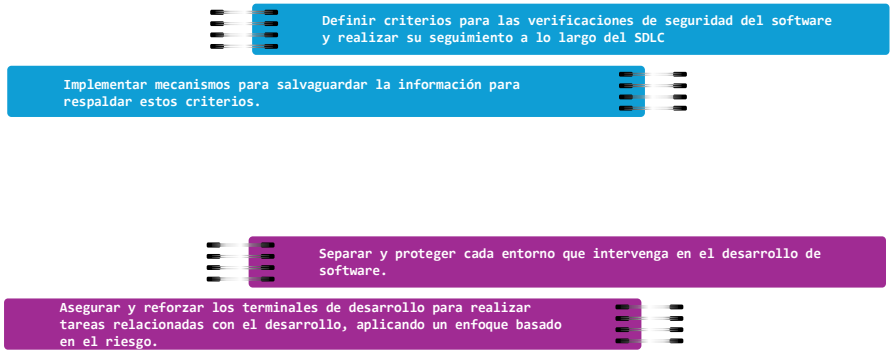
Definir y utilizar criterios para las verificaciones de seguridad del software

Contribuir a garantizar que el software resultante del ciclo de vida de desarrollo de software (SDLC) cumpla con las expectativas de la organización mediante la definición y aplicación de criterios para verificar la seguridad del software durante el desarrollo.

05

Implementar y mantener entornos seguros para el desarrollo de software

Garantizar que todos los componentes de los entornos de desarrollo de software estén fuertemente protegidos frente a amenazas internas y externas, a fin de evitar que se vean comprometidos dichos entornos o el software que se desarrolla o mantiene en ellos.



FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

2. Proteger al Software (PS)

01

Proteger todas las formas de código contra el acceso no autorizado y la manipulación

prevenir modificaciones no autorizadas en el código —tanto accidentales como intencionadas— que podrían eludir o anular las características de seguridad previstas del software.

02

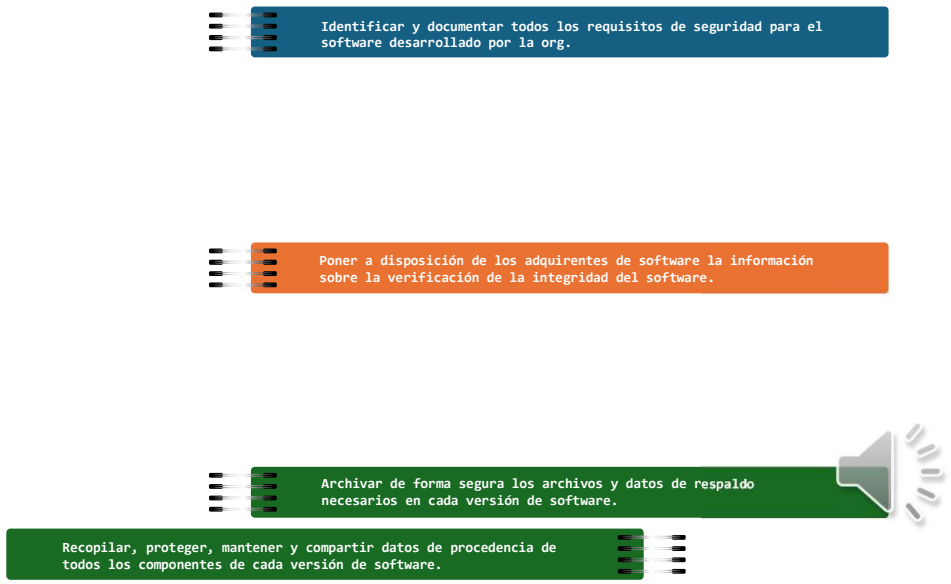
Establecer un mecanismo para verificar la integridad de la versión del software

Ayudar a los adquirientes de software a garantizar que el software que adquieren sea legítimo y no haya sido manipulado.

03

Archivar y proteger cada versión de software

Conservar las versiones de software para ayudar a identificar, analizar y eliminar vulnerabilidades descubiertas en el software tras su lanzamiento.



FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

3. Producir Software Altamente Seguro (PW)

01

Diseñar software para cumplir con los requisitos de seguridad y mitigar sus riesgos

Evaluar los requisitos de seguridad del software; determinar a qué riesgos de seguridad es probable que se enfrente el software durante su funcionamiento y cómo el diseño y la arquitectura del mismo deben mitigar dichos riesgos

02

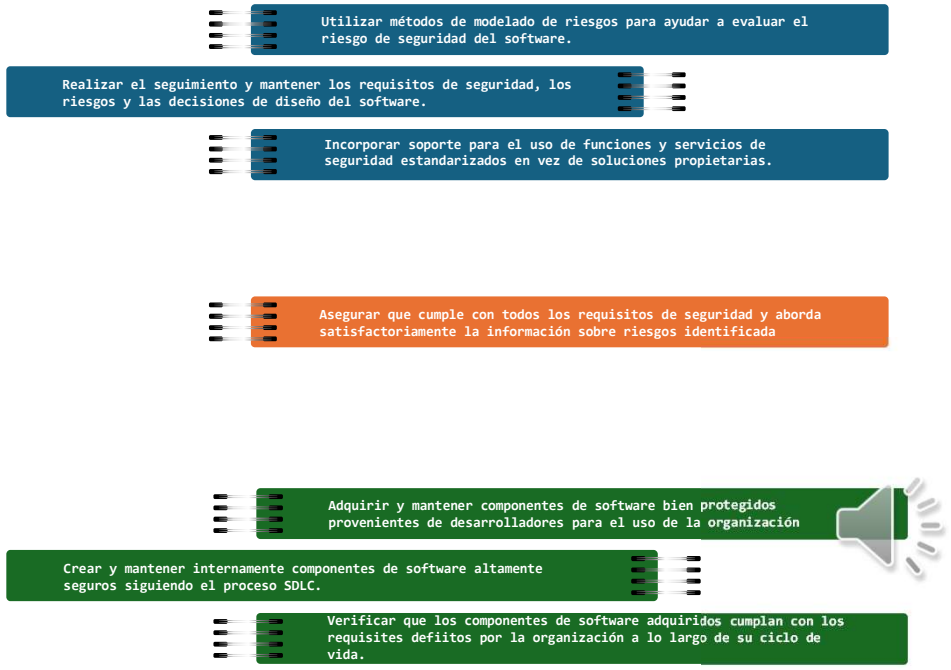
Verificar el cumplimiento de los requisitos de seguridad y los riesgos

Ayudar a garantizar que el software cumpla con los requisitos de seguridad y aborde satisfactoriamente la información sobre riesgos identificada.

04

Reutilizar software existente y en lugar de duplicar funcionalidades

Reducir los costos y agilice el desarrollo de software, además de disminuir la probabilidad de introducir vulnerabilidades de seguridad adicionales, mediante la reutilización de módulos y servicios de software cuya postura de seguridad ya haya sido verificada.



3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

3. Producir Software Altamente Seguro (PW)

05

Seguir las prácticas de programación segura

Disminuir el número de vulnerabilidades de seguridad en el software y reducir costos minimizando las vulnerabilidades introducidas durante la creación del código fuente que cumplan o superen los criterios de gravedad de vulnerabilidades .

06

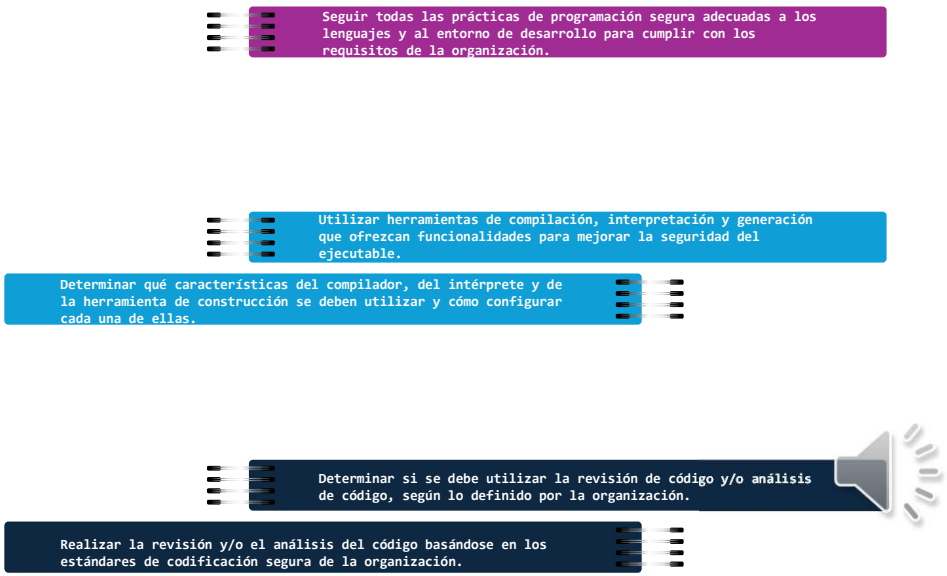
Configurar los procesos de compilación, interpretación y generación de la aplicación para mejorar la seguridad del ejecutable

Disminuir el número de vulnerabilidades de seguridad en el software y reducir los costos eliminando dichas vulnerabilidades antes de la fase de pruebas.

07

Revisar el código legible por humanos para identificar vulnerabilidades y verificar el cumplimiento de los requisitos de seguridad

Ayudar a identificar vulnerabilidades para que puedan corregirse antes de la publicación del software, evitando así su explotación.



FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

3. Producir Software Altamente Seguro (PW)

08

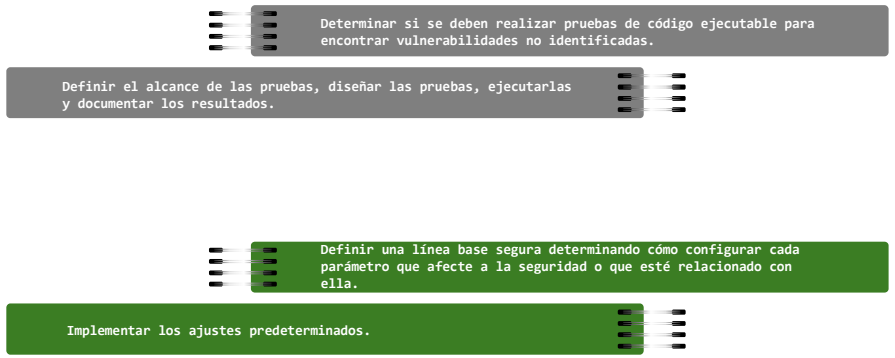
Probar el código ejecutable para identificar vulnerabilidades y verificar el cumplimiento de los requisitos de seguridad

Ayudar a identificar vulnerabilidades para que puedan corregirse antes de la publicación del software, con el fin de prevenir su explotación

09

Configurar el software con ajustes seguros por defecto

Contribuir a mejorar la seguridad del software durante la instalación para reducir la probabilidad de que se implemente con configuraciones de seguridad débiles, lo que aumentaría el riesgo de vulneración.



FADENA

3.3 Protección Proactiva

NIST Secure Software Development Framework (SSDF)

4. Responder a las vulnerabilidades (RV)

01

Identificar y confirmar vulnerabilidades de forma continua

Contribuir a garantizar que las vulnerabilidades se identifiquen con mayor rapidez para que puedan subsanarse más velozmente en función del riesgo.

02

Evaluar, priorizar y remediar vulnerabilidades

Contribuir a garantizar que las vulnerabilidades se remedien en función del riesgo para reducir la ventana de oportunidad para los atacantes.

03

Analizar vulnerabilidades para identificar sus causas raíz

Ayudar a reducir la frecuencia de vulnerabilidades en el futuro.

